

Evidence before verdicts

SIH26155 | AI-Driven Multi-Vendor Network Security Compliance Auditor

Purpose and adaptation mechanism

Upload configurations, normalize supported facts, evaluate reviewed controls and export evidence. Unfamiliar syntax enters a bounded Gemini investigation: retrieve references, propose a mapping, test positive/negative cases, request clarification, and require reviewer activation. A new audit uses the approved mapping without code deployment. Prior versions stay pinned.

Runtime architecture

Browser -> NGINX gateway -> stateless FastAPI replicas -> PostgreSQL / Valkey / encrypted S3. Keycloak provides OIDC with PKCE; server-side sessions carry trusted organization membership. Worker replicas claim durable jobs with leases and fencing. A separate stage creates device PDFs. Gemini requests pass through a proxy restricted to Google inference endpoints. Maintenance expires artifacts, completes deletion and reconciles orphaned objects. Optional Prometheus/Grafana and OTLP profiles expose operational evidence.

Data and service ownership

PostgreSQL: tenant records, immutable input/policy/mapping references, sessions, jobs and events. SeaweedFS S3: AES-GCM encrypted source snapshots and reports, with SHA-256 integrity checks. Valkey: distributed token buckets, provider concurrency permits and token reservations. One shared Python domain package keeps worker logic consistent across independent processes.

Source and interpretation boundaries

20 team-authored technical checks; initial IOS/IOS-XE, Junos set and FortiOS subsets. Text/JSON/XML mappings have fixed selectors and types; generated code is never executed. Unknown, conflicting or unsupported effective settings never silently become a pass. The organizer supplied a reference list, not a dataset. Shipped samples are synthetic. Framework selections are candidate crosswalks, not full certified CIS/NIST/STIG/ISO packs.

Security, recovery and qualification

SIH26155 | AI-Driven Multi-Vendor Network Security Compliance Auditor

Security controls

Organization-scoped authorization plus PostgreSQL RLS under non-owner runtime roles.
CSRF/origin checks, server-side sessions, role-gated reviews and Secure cookies in TLS mode.
Bounded uploads/parsing, credential redaction, no live-device access or arbitrary agent tools.
Shared limits, separate internal networks and verified TLS to fixed Google upstream hosts.
Runtime roles append events but cannot rewrite history; database administrators remain trusted.

Fault tolerance and recovery

75-second job lease, 15-second heartbeat, fencing and bounded retries; at-least-once effects.
Valkey outage refuses expensive work while allowing tightly limited evidence browsing.
Consistent encrypted backup includes application/identity databases and encrypted objects.
Restore into fresh volumes verifies record counts and every referenced artifact hash.
One local host is one failure domain; no cloud deployment or uptime SLA is claimed.

Recorded qualification

Real browser tests cover OIDC, cross-tenant access, roles, mapping activation/rollback and PDFs.
Worker recovery: 79.44 seconds; accepted work completed.
Restore rehearsal: 31.27 seconds; plaintext artifact integrity checked.
Deterministic throughput: Pending qualification configurations/minute.
Metadata p95: Pending qualification ms. Full conditions and caveats: docs/verification.md.

Remaining external validation

Independent expert-labelled vendor/firmware cases and licensed exact benchmark content.
Controlled comparisons and ablations before any accuracy or novelty-superiority claim.
Operational validation of proposed changes; no device commands are automatically applied.
Future hosting requires real membership lifecycle, key rotation and host-level redundancy.